

Care Access Navigator

CloudSec1 Rubric — Criterion 4: Identity & Access Management Implementation
Evidence Package — Keycloak ↔ Microsoft Entra ID Federation & RBAC Role Assignment

Prepared by:	Akhila Chennamaneni
Capstone:	Care Access Navigator (HealthLine Regional Medical Center)
Rubric criterion:	Criterion 4 — Identity & Access Management Implementation (CloudSec1)
Environment:	Keycloak 26.0 (Docker, realm: care-access-navigator) ↔ Microsoft Entra ID (Default Directory)
Evidence date:	September 30, 2026

Objective

Criterion 4 requires a direct cloud extension of the Keycloak identity provider and CAN's seven-role RBAC model, implemented as federation from Keycloak into the cloud provider's identity platform. This package documents the genuine, tested configuration of OpenID Connect (OIDC) federation between Keycloak (CAN's primary IdP) and Microsoft Entra ID, followed by automatic least-privilege role assignment for a federated identity.

Scope of this evidence package

- Entra ID app registration verification and client secret generation
- Redirect URI configuration linking Entra ID to the Keycloak broker endpoint
- Keycloak OIDC Identity Provider configuration (discovery endpoints, client credentials)
- End-to-end federated login test (Microsoft sign-in → Keycloak account console)
- Existing attribute mappers (email, first name, last name, username) confirmed
- RBAC role mapper (Hardcoded Role, Force sync) assigning the security-analyst CAN role on login
- A genuine configuration error encountered and resolved (documented below, not hidden)
- Final verification: role mapping confirmed on the federated user account

Federation Architecture

Keycloak (realm **care-access-navigator**) is configured with Microsoft Entra ID as an OpenID Connect Identity Provider, aliased **entra-id**. When a user authenticates through the entra-id button on Keycloak's login page, they are redirected to Microsoft's real sign-in flow. On successful authentication, Microsoft returns an ID token to Keycloak at the broker endpoint below, and Keycloak provisions/updates a local federated user record, applying attribute mappers (profile sync) and role mappers (RBAC assignment) automatically.

Component	Value
Keycloak realm	care-access-navigator
Identity Provider alias	entra-id
Entra ID app registration	care-access-navigator-keycloak-broker
Entra ID tenant	02de1b12-6fec-4370-b0fe-3c115598cdac
Redirect URI (broker endpoint)	http://localhost:8080/realms/care-access-navigator/broker/entra-id/endpoint
Authorization / Token / JWKS	https://login.microsoftonline.com/{tenant-id}/... (v2.0 OIDC endpoints)
Client authentication	Client secret sent as POST
Assigned CAN RBAC role	security-analyst
Sync mode override	Force (role re-asserted on every login)

Step-by-Step Implementation Evidence

STEP 1

Verify Entra ID App Registration & Generate Client Secret

The app registration **care-access-navigator-keycloak-broker** already existed with two prior client secrets, both masked and unverifiable. Rather than risk using a secret whose full value was never confirmed as saved, a fresh client secret was generated and copied immediately, since Entra ID reveals a secret's full value only once, at creation.

home > Default directory | App registrations > care-access-navigator-keycloak-broker

care-access-navigator-keycloak-broker | Certificates & secrets

Search Got feedback?

Overview
Quickstart
Integration assistant
Diagnose and solve problems
Manage
Branding & properties
Authentication (Preview)
Certificates & secrets
Token configuration
API permissions
Expose an API
App roles
Owners
Roles and administrators
Manifest
Support + Troubleshooting

Credentials enable confidential applications to identify themselves to the authentication service when receiving tokens at a web addressable location (using an HTTPS scheme). For a higher level of assurance, we recommend using a certificate (instead of a client secret) as a credential.

Application registration certificates, secrets and federated credentials can be found in the tabs below.

Certificates (0) **Client secrets (2)** Federated credentials (0)

A secret string that the application uses to prove its identity when requesting a token. Also can be referred to as application password.

+ New client secret

Description	Expires	Value	Secret ID
Keycloak broker secret	3/20/2027	jRg*****	c7fd7a0f-805e-4704-8b8b-afad081d8913
Keycloak_New_secret	3/20/2027	-lA*****	e9919ab7-073e-4bf1-b7d5-eea6f6cdbf9c

Figure 1. Entra ID app registration — Certificates & secrets page, client secret generated.

STEP 2

Configure the Redirect URI

The app registration's Authentication settings were configured with a Web platform redirect URI pointing to Keycloak's broker endpoint for the entra-id provider alias, ensuring Microsoft's authentication response is delivered back to the correct Keycloak callback.

Verification note: the alias segment (entra-id) in this URL must match the Identity Provider alias configured in Keycloak exactly, or the federated login will fail to resolve.

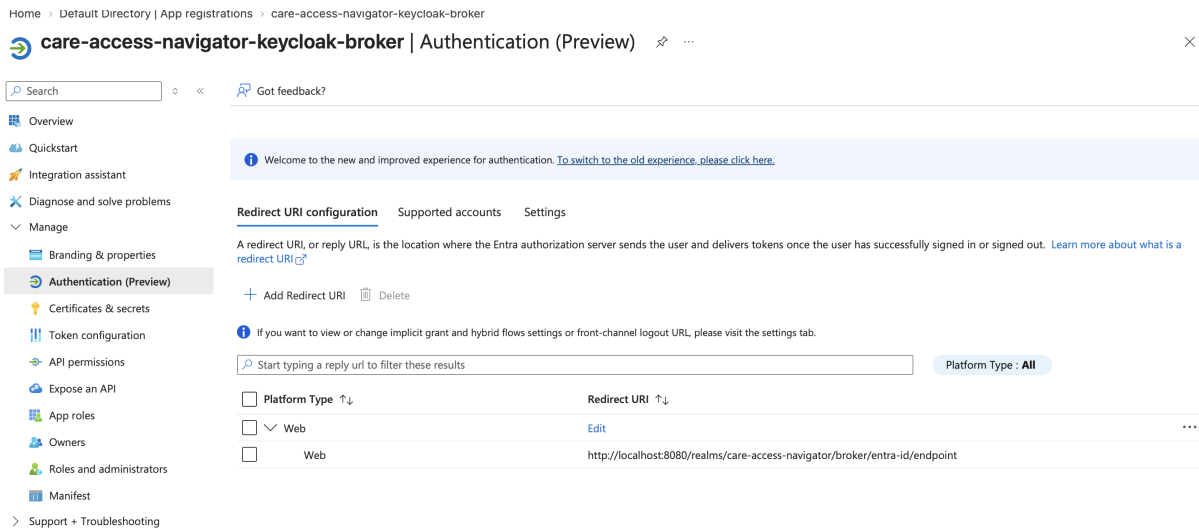


Figure 2. Entra ID app registration — Authentication page, redirect URI confirmed: `http://localhost:8080/realms/care-access-navigator/broker/entra-id/endpoint`

STEP 3

Configure the Keycloak OIDC Identity Provider

In the `care-access-navigator` realm, an OpenID Connect v1.0 Identity Provider was configured with alias **entra-id**. The discovery endpoint resolved Entra ID's Authorization URL, Token URL, Logout URL, User Info URL, Issuer, and JWKS URL automatically, confirming Keycloak could successfully reach Entra ID's OIDC metadata for this tenant.

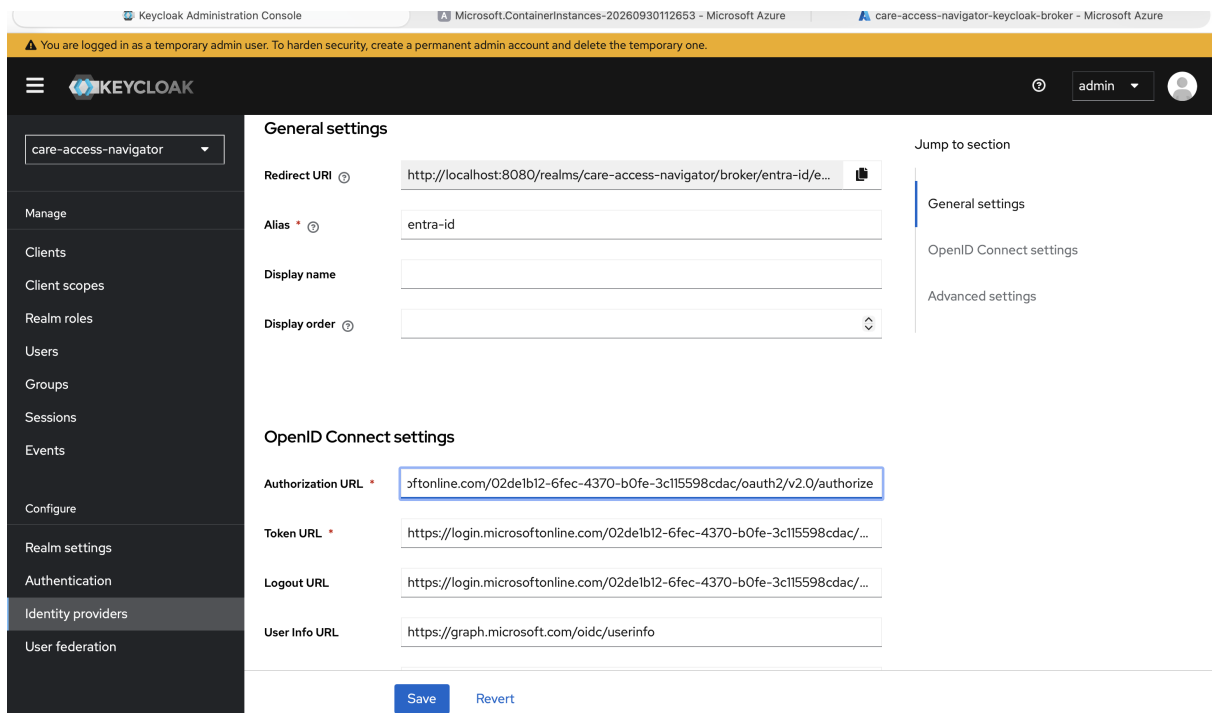


Figure 3. Keycloak Identity Provider — General settings and OpenID Connect settings, auto-resolved Entra ID endpoints for tenant `02de1b12-6fec-4370-b0fe-3c115598cdac`.

STEP 3b

Confirm Client Credentials in Keycloak

Scrolling further into the same provider configuration confirmed Client authentication was set to “Client secret sent as POST,” the Client ID matched the Entra ID app registration exactly, and the Client Secret field was refreshed with the newly generated secret from Step 1 to eliminate any ambiguity from the prior unverified secrets.

The screenshot displays the Keycloak Administration Console interface. The top navigation bar includes the Keycloak logo and a user profile dropdown set to 'admin'. A warning banner at the top states: 'You are logged in as a temporary admin user. To harden security, create a permanent admin account and delete the temporary one.' The left sidebar contains a navigation menu with options: Manage, Clients, Client scopes, Realm roles, Users, Groups, Sessions, Events, Configure, Realm settings, Authentication, Identity providers (selected), and User federation. The main content area shows the configuration for the 'care-access-navigator' identity provider. The settings are as follows:

- Token URL:** `https://login.microsoftonline.com/02de1b12-6fec-4370-b0fe-3c115598cdac/...`
- Logout URL:** `https://login.microsoftonline.com/02de1b12-6fec-4370-b0fe-3c115598cdac/...`
- User Info URL:** `https://graph.microsoft.com/oidc/userinfo`
- Issuer:** `https://login.microsoftonline.com/02de1b12-6fec-4370-b0fe-3c115598cdac/v...`
- Validate Signatures:** ☒ On
- Use JWKS URL:** ☒ On
- JWKS URL:** `https://login.microsoftonline.com/02de1b12-6fec-4370-b0fe-3c115598cdac/discovery/v2.0/keys`
- Use PKCE:** ☐ Off
- Client authentication:** Client secret sent as post
- Client ID:** `bffd8f86-c142-4204-9deb-3a578ae245ef`
- Client Secret:** [Masked]

At the bottom of the configuration form are 'Save' and 'Revert' buttons. On the right side, there is a 'Jump to section' menu with options: General settings, OpenID Connect settings (selected), and Advanced settings.

Figure 4. Keycloak Identity Provider — Client ID, Client Secret, and signature validation settings.

STEP 4

End-to-End Federated Login Test — Success

With configuration complete, the entra-id login button on the realm's account console was used to trigger a real authentication flow: Keycloak redirected to Microsoft's sign-in page, the user authenticated with a genuine Entra ID identity, and Microsoft redirected back to Keycloak. The resulting account console page confirms a successful login, with the user's profile (name, email) auto-populated from the federated identity token.

localhost:8080/realms/care-access-navigator/account

KEYCLOAK

Akhila Chennamaneni

Personal info

Account security

Applications

Personal info

Manage your basic information

General

Jump to section

General

Username * entra-id.

Email * ch.akhilarao@gmail.com

First name * Akhila

Last name * Chennamaneni

Save Cancel

Figure 5. Keycloak account console, post-federation — logged in as Akhila Chennamaneni via entra-id, profile fields synced from the Entra ID token.

STEP 5

Confirm Existing Attribute Mappers

Before adding RBAC logic, the entra-id provider's existing Mappers were reviewed: a username-template mapper (preprocessor) plus three Attribute Importer mappers for email, first name, and last name. These explain the profile auto-population seen in Step 4 and confirm identity attribute sync was already correctly implemented.

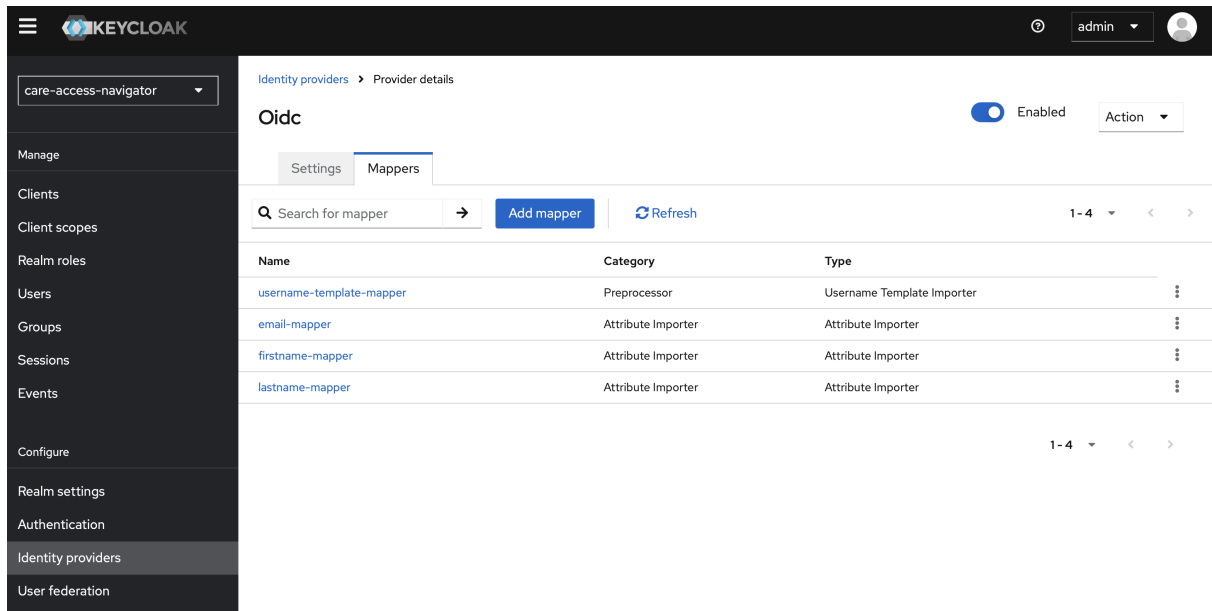


Figure 6. Keycloak Identity Provider Mappers tab — four existing attribute mappers (pre-RBAC-mapper state).

STEP 6

Add the RBAC Role Mapper — Troubleshooting a Real Configuration Error

A Hardcoded Role mapper was added with Sync Mode Override set to **Force**, so the assigned CAN role is re-asserted on every federated login rather than only at first account creation. The first attempt used the role name **Security-Analyst** and produced no visible role assignment after a fresh login. Checking the realm's actual Realm roles list revealed the true role name is lowercase and hyphenated: **security-analyst** — the mapper had silently failed to resolve a role name that did not exist as typed.

Root cause & fix: role names in Keycloak's Hardcoded Role mapper must reference an existing realm role exactly. The mapper was recreated selecting security-analyst directly from the dropdown (rather than typed manually) to eliminate any further mismatch.

care-access-navigator

Manage

Clients

Client scopes

Realm roles

Users

Groups

Sessions

Events

Configure

Realm settings

Authentication

Identity providers

User federation

KEYCLOAK

admin

Realm roles

Realm roles are the roles that you define for use in the current realm. [Learn more](#)

Q Search role by name

Create role

Refresh

1 - 10

Role name	Comp...	Description
billing	False	Access to the Billing App and billing-relevant patient/claims data only (charges, insurance/claims status, payment records); explicitly n
clinician	False	Front-line care provider access. Represents the role with the broadest ePHI access.
default-roles-care-access-navigator	True	role_default-roles
hr	False	Access to the HR App and workforce records (employee records, onboarding/offboarding status, role assignments); no access to any f
it-support	False	Administrative/helpdesk access: ability to view user account status and assist with access issues (e.g., password resets) but not standir
nurse	False	Supporting clinical access. Illustrates a least-privilege distinction between two clinical roles with overlapping but not identical access.
offline_access	False	role_offline-access
security-analyst	False	Access to security monitoring and logging tools (SIEM, authentication logs, Keycloak Events) across the environment for investigation
uma_authorization	False	role_uma_authorization
vendor	False	External/third-party access, narrowly scoped to a specific system or time-limited engagement (e.g., a specific application module or a

1 - 10

Figure 7. Keycloak Realm roles — confirms the seven CAN RBAC roles (billing, clinician, hr, it-support, nurse, security-analyst, vendor) and the exact casing required for the role mapper.

STEP 7

Re-Test Federated Login After the Fix

The account console session was signed out and a fresh federated login was performed in a private browsing window to force a new authentication event, since role mappers with Force sync only re-apply at the moment of login — not retroactively to an already-active session.

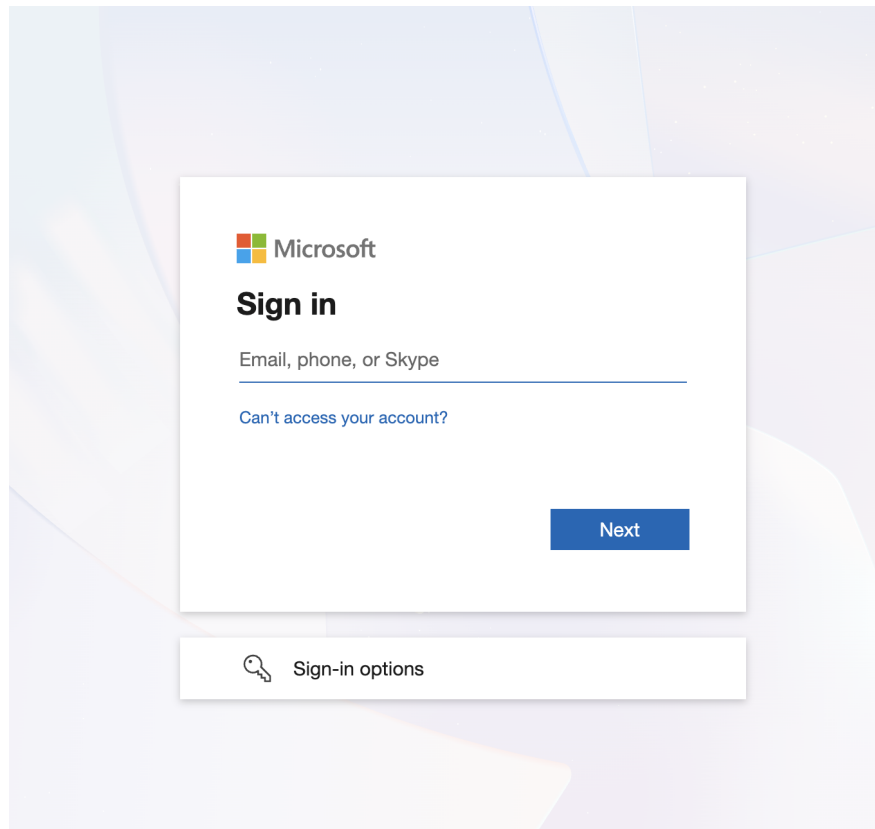


Figure 8. Microsoft sign-in page during the repeat federated login test.

STEP 7b

Identify the Federated User Record

In the Keycloak admin console, the Users list confirms a single federated user record (username entra-id., email ch.akhilarao@gmail.com, name Akhila Chennamaneni) was created by the federation — distinct from the seven synthetic test.[role]01 accounts used elsewhere in CAN's native RBAC testing.

Keycloak Admin Console

You are logged in as a temporary admin user. To harden security, create a permanent admin account and delete the temporary one.

care-access-navigator

Users
Users are the users in the current realm. [Learn more](#)

User list

Attribute search Select attributes Add user Delete user Refresh 1 - 8

☐	Username	Email	Last name	First name	
☐	entra-id.	ch.akhilarao@gmail.com	Chennamaneni	Akhila	⋮
☐	test.billing1	test.billing1@care-access-lab.local	—	billing1_Rob	⋮
☐	test.clinician1	test.clinician1@care-access-lab.local	one	clinician1_Tom	⋮
☐	test.hr1	test.hr1@care-access-lab.local	—	hr1_Ram	⋮
☐	test.itsupport1	test.itsupport1@care-access-lab.local	—	itsupport1_Dan	⋮
☐	test.nurse1	test.nurse1@care-access-lab.local	—	nurse1_Pam	⋮
☐	test.secanalyst1	test.secanalyst1@care-access-lab.local	—	secanalyst1_Sam	⋮
☐	test.vendor1	test.vendor1@care-access-lab.local	—	vendor1_Krish	⋮

1 - 8

Figure 9. Keycloak Users list — the federated entra-id. account alongside CAN's existing synthetic test users.

STEP 8

Final Verification — Role Successfully Applied

Opening the federated user's Role mapping tab after the corrected mapper and repeat login confirms **security-analyst** is now assigned, alongside the realm's default role. This is the conclusive evidence that federated authentication and automatic least-privilege RBAC assignment are both functioning together as designed.

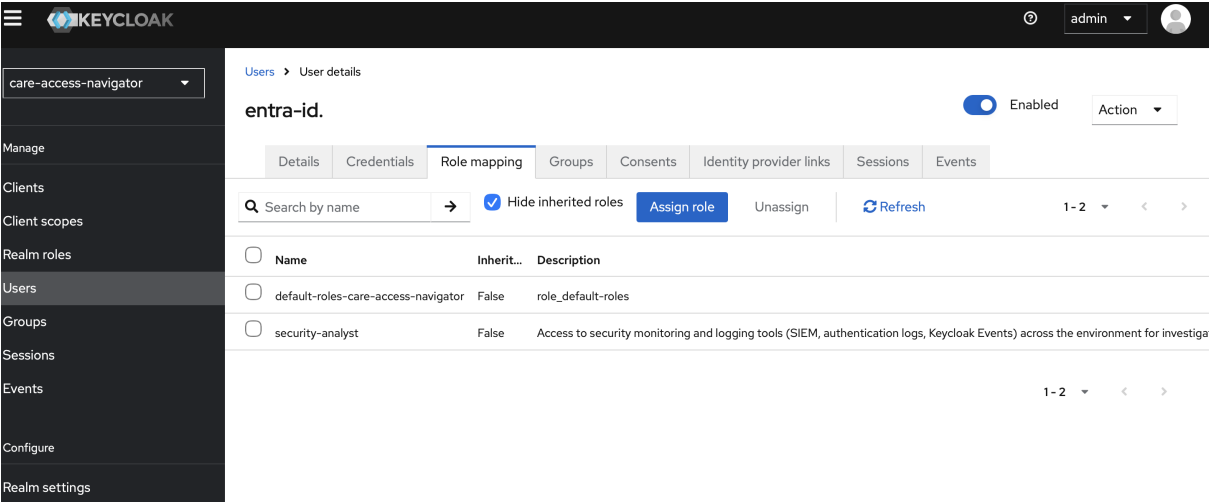


Figure 10. Keycloak Role mapping tab — security-analyst role confirmed on the federated user (FINAL EVIDENCE).

Compliance & Control Mapping

Control Area	HIPAA Security Rule	NIST CSF 2.0	CAN Evidence
Federated authentication	§164.312(d) Person/Entity Authentication	PR.AA-01 (Identity management)	Figures 3–5 (OIDC federation, successful login)
Automatic least-privilege role assignment	§164.308(a)(4) Information Access Management	PR.AA-05 (Access permissions managed)	Figures 6–10 (role mapper, verified assignment)
Credential management	§164.312(a)(2)(i) Unique User Identification	PR.AA-01	Figure 1 (client secret lifecycle, stale-secret avoidance)

Implementation Status

Implemented & verified: OIDC federation (Keycloak ↔ Entra ID), profile attribute sync, automatic RBAC role assignment via Hardcoded Role mapper (Force sync) for a single federated identity.

Known limitation (by design, for this pass): The current role mapper applies **security-analyst** to any user authenticating through this Entra ID provider. It does not yet differentiate federated users into different CAN roles.

Planned enhancement: Replace the Hardcoded Role mapper with an Attribute Importer mapper driven by real Entra ID group claims, so different federated identities map to different CAN roles (Clinician, Nurse, Billing, HR, IT-Support, Security-Analyst, Vendor). This requires configuring groupMembershipClaims on the app registration manifest and assigning test identities to distinct Entra ID groups — out of scope for today's build due to the Azure credit expiration window.

This evidence was captured on 2026-09-30, the final day of the Azure subscription credit window. Steps requiring live Entra ID portal access (Steps 1–2) were completed first; Keycloak-side configuration and testing (Steps 3–8) do not depend on continued Azure billing, since Keycloak runs locally via Docker.